VE03 - Forensische Datensicherung

① Order of Volatility (Reihenfolge der Sicherung)

1. CPU-Cache (nicht sicherbar)
2. RAM (Passwörter, Malware, Prozesse)
3. Netzwerk/System (Offene Verbindungen)
4. Festplatte/SSD (Persistent)
5. Archivmedien (Backups) (Persistent)

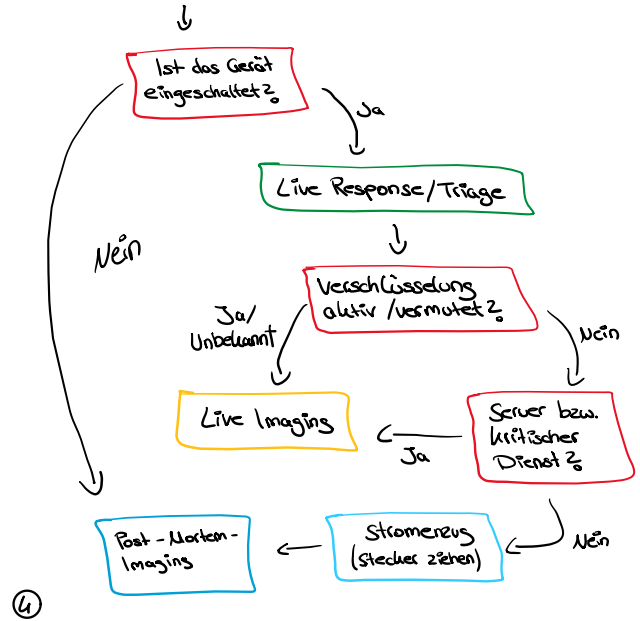
② Live Response (Am laufendem System)

- Locard-Regeln: Nichts installieren, nur Tools vom USB-Stick nutzen, Ergebnisse auf USB-Stick umleiten (Zielsystem nicht ändern)
- RAM: sichern z.b. mit WinPmem
- Systemzustand: Skripte für Zeit, Netz (netstat), Prozesse (tasklist).
- Triage (KAPE): Schnelle, gezielte Sicherung wichtiger Windows-Artefakte (Logs) in wenigen Minuten.

③ Entscheidung: Abschalten (Stecker ziehen) vs. Anlassen

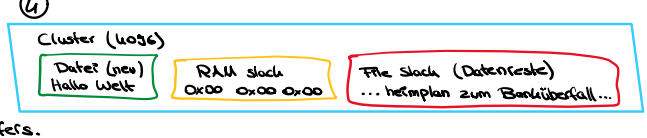
- Standard: Netztrennung (Kabel ziehen) -> RAM bleibt erhalten.
- Stromentzug (RAM opfern) nur wenn: Ein Verschlüsselungs-Schaden läuft (und sich nicht anders stoppen lässt)
- Achtung Verschlüsselung: Wenn Bitlocker / Festplattenverschlüsselung aktiv ist und der Schlüssel fehlt, niemals den Pc ausschalten (sonst sind alle Daten für immer unlesbar)! Stattdessen: Live Disk Imaging am laufenden Pc.
- Herunterfahren? Nicht normal herunterfahren (verändert Logs und Zeitstempel)

Entscheidung: Live oder Post-Mortem



④ Forensisches Image vs. Backup

- Backup: kopiert nur aktive Dateien (Forensisch nutzlos)
- Image: Bitgenaue 1:1-Kopie der gesamten Festplatte (Sektor 0 bis Ende). Sichert auch gelöschte Daten und Slack Space.
- Write-Blocker: Hardware, die beim Anstecken der Beweis-Festplatte alle Schreibbefehle von Windows blockt. Nötig.
- Hashing (SHA-256): Beweist die Echtheit. Hash-Wert vom Original muss exakt mit dem Hash-Wert des Images übereinstimmen
- Chain of Custody: Lückenloses Protokoll (wer, wann, was) + Hash-Werte = garantiert Gerichtsverwertbarkeit.



⑤ IOCs und Tor-Netzwerk

- IOC: Erkennungsmerkmal (z.b. Hash-Wert), um den Angriff auf anderen Pcs zu finden. IPs/Dateinamen sind schlechte IOCs, Hashes sind gute IOCs.
- TOR (.onion): Angreifer nutzen das Tor-Netzwerk. Der Datenverkehr springt über viele Server Weltweit. Die Firma sieht nur den "Exit Node", nicht die echte IP des Angreifers.